

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC FPT**

**KIẾN TRÚC NHẬN THỨC HAI TẦNG CHO PHÁT HIỆN
VÀ PHẢN HỒI MỖI ĐE DỌA TỰ ĐỘNG SỬ DỤNG AI
TÁC TỬ (AGENTIC AI)**

thực hiện bởi

Nguyễn Đức Bình

Luận văn được nộp để đáp ứng yêu cầu
của học vị Thạc sĩ Kỹ thuật Phần mềm

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC FPT**

**KIẾN TRÚC NHẬN THỨC HAI TẦNG CHO PHÁT HIỆN
VÀ PHẢN HỒI MỐI ĐE DỌA TỰ ĐỘNG SỬ DỤNG AI
TÁC TỬ (AGENTIC AI)**

thực hiện bởi

Nguyễn Đức Bình

Luận văn được nộp để đáp ứng yêu cầu
của học vị Thạc sĩ Kỹ thuật Phần mềm

Giảng viên hướng dẫn:

TS. Bùi Văn Hiệu

TS. Đặng Văn Hiếu

Tóm tắt

Trong bối cảnh an ninh mạng hiện đại, các Trung tâm Điều hành An ninh (SOC) đối mặt với áp lực quá tải khi khối lượng cảnh báo nhật ký vượt quá khả năng xử lý thủ công. Các công cụ tự động hóa truyền thống vận hành theo kịch bản tĩnh thiếu khả năng suy luận, trong khi việc đưa trực tiếp dữ liệu vào Mô hình Ngôn ngữ Lớn (LLM) lại gặp rào cản độ trễ, nguy cơ tiêm nhiễm câu lệnh (prompt injection) và vi phạm chủ quyền dữ liệu. Luận văn đề xuất SENTINEL, một kiến trúc an ninh nhận thức hai tầng vận hành cục bộ (air-gapped) giải quyết triệt để các rào cản trên. Tầng 1 vận hành như một bộ lọc tốc độ đường truyền nhằm tự động loại bỏ phần lớn lưu lượng nhiễu, trong khi Tầng 2 ứng dụng tác tử AI suy luận có trạng thái kết hợp tri thức MITRE ATT&CK và quy định NIST để xử lý các đe dọa phức tạp đằng sau các rào chắn mật mã.

Đánh giá thực nghiệm trên các tập dữ liệu xâm nhập chuẩn mực minh chứng hiệu năng vượt trội của SENTINEL. Tầng 1 xả tải tự động 92.2% lưu lượng nhiễu ở độ trễ dưới 1 ms và đạt băng thông trên 2.500 flows/s. Tầng 2 đạt độ chính xác quy kết kỹ thuật 67.33% (RRF) và kiểm soát hoàn toàn tỷ lệ bỏ lọt tấn công so với mô hình Đơn tầng. Cơ chế đóng gói Nonce vô hiệu hóa 100% tấn công prompt injection, kết hợp niêm phong HMAC-SHA256 bảo đảm tính toàn vẹn vết chứng cứ. Hệ thống vận hành hoàn toàn cục bộ trên GPU 16 GB với mức tiêu thụ tài nguyên tối ưu, khẳng định kiến trúc lai hai tầng là giải pháp thiết thực và hiệu quả cho phòng thủ SOC hiện đại.

Lời cảm ơn

Để hoàn thành công trình nghiên cứu khoa học này và đạt được học vị Thạc sĩ Kỹ thuật Phần mềm, tôi đã nhận được sự hỗ trợ, động viên và đùm bọc quý báu từ rất nhiều cá nhân và tập thể.

Trước hết, tôi xin bày tỏ lòng biết ơn chân thành và kính trọng sâu sắc nhất tới hai thầy hướng dẫn khoa học của tôi, TS. Bùi Văn Hiệu và TS. Đặng Văn Hiếu. Với tri thức học thuật uyên bác, sự định hướng chiến lược chuẩn xác và tinh thần làm việc nghiêm túc, quý thầy đã luôn dành thời gian kiên nhẫn chỉ bảo, định hướng tư duy phản biện và truyền cảm hứng nghiên cứu cho tôi trong suốt chặng đường thực hiện luận văn. Những góp ý chuyên môn sắc bén của quý thầy không chỉ giúp tôi từng bước hoàn thiện công trình này mà còn là hành trang tri thức vô giá cho sự nghiệp nghiên cứu an toàn thông tin và trí tuệ nhân tạo của tôi sau này.

Tôi xin trân trọng gửi lời tri ân tới Ban Giám hiệu, Ban Lãnh đạo Viện Quản trị & Công nghệ FSB cùng toàn thể quý thầy cô giáo Trường Đại học FPT. Quý thầy cô đã truyền dạy cho tôi những nền tảng tri thức lý thuyết và thực tiễn vững chắc, đồng thời tạo một môi trường học tập, nghiên cứu chuyên nghiệp, hiện đại, tạo mọi điều kiện thuận lợi nhất cho học viên nâng cao trình độ chuyên môn trong suốt khóa học Thạc sĩ.

Tôi xin chân thành cảm ơn Ban Lãnh đạo cùng các đồng nghiệp tại Cục C12, Trung tâm Dữ liệu Quốc gia. Sự tin tưởng, tạo điều kiện thuận lợi về mặt thời gian cùng những kinh nghiệm thực chiến vô cùng phong phú từ môi trường công tác thực tế tại đơn vị đã tiếp thêm cho tôi nhiều động lực và góc nhìn thực tiễn sâu sắc để áp dụng trực tiếp vào quá trình thiết kế, thực nghiệm và kiểm chứng hệ thống an ninh SENTINEL.

Cuối cùng, và cũng là niềm tự hào lớn lao nhất, tôi xin dành trọn lòng tri ân sâu sắc nhất tới gia đình thân yêu của mình, đặc biệt là người vợ hiền cùng con nhỏ. Sự hy sinh thầm lặng, lòng kiên nhẫn vô bờ bến, sự thấu hiểu và nguồn động viên tinh thần không ngừng nghỉ của vợ và con trong suốt những tháng ngày tôi miệt mài bên máy tính với các đợt thực nghiệm kéo dài xuyên đêm chính là điểm tựa tinh thần vững chắc nhất, giúp tôi vượt qua mọi rào cản và khó khăn để hoàn thành tốt đẹp công trình nghiên cứu này.

Mặc dù đã rất cố gắng nghiêm túc hoàn thiện luận văn với tất cả tinh thần trách nhiệm và lòng nhiệt huyết khoa học, song công trình khó tránh khỏi những hạn chế nhất định. Tôi rất mong nhận được sự chỉ dẫn, đóng góp ý kiến quý báu từ quý thầy cô trong Hội đồng chấm luận văn và các đồng nghiệp để đề tài tiếp tục được hoàn thiện và phát triển hơn nữa trong tương lai.

Mục lục

Tóm tắt	1
Lời cảm ơn	2
Danh sách hình vẽ	5
Danh sách bảng	6
Danh mục các từ viết tắt	7
1 Giới thiệu	8
1.1 Bối cảnh và Động lực Nghiên cứu	8
1.2 Mục tiêu Nghiên cứu	9
1.3 Câu hỏi Nghiên cứu	9
1.4 Phạm vi và Đối tượng Nghiên cứu	10
1.5 Phương pháp Nghiên cứu	10
1.6 Đóng góp Cốt lõi của Luận văn	11
1.7 Cấu trúc của Luận văn	12
2 Cơ sở Lý thuyết và Tổng quan Nghiên cứu	13
2.1 Thực trạng Vận hành SOC và Nút thắt Nhận thức	13
2.2 Lý thuyết Thống kê Trực tuyến và Học máy Tầng 1	13
2.3 Mô hình Ngôn ngữ Lớn Cục bộ và Trí tuệ Tác tử Tầng 2	14
2.4 An ninh Đối kháng AI và Mật mã học Kiểm toán Nhật ký	14
2.5 Tổng quan Nghiên cứu Liên quan và Khoảng trống Nghiên cứu	15
3 Thiết kế Hệ thống và Triển khai Kỹ thuật	17
3.1 Kiến trúc Tổng thể SENTINEL và Tích hợp Ngăn xếp SOC	17
3.2 Tầng 1: Bộ lọc Tốc độ Đường truyền và Cổng Học máy	19
3.3 Tầng 2: Tác tử Nhận thức LangGraph và Bộ nhớ Đe dọa	20
3.4 Cơ chế Truy xuất Tri thức Lai Dual-RAG	21
3.5 Kiến trúc An ninh AI và Niêm phong Kiểm toán Mật mã	21
3.6 SOC Dashboard và Kiến trúc Triển khai Cục bộ	22
4 Thực nghiệm và Đánh giá	24
4.1 Môi trường Thực nghiệm và Tập Dữ liệu Giám sát	24
4.2 Hiệu năng Giảm tải Tầng 1 và Độ trễ Đường truyền	25
4.3 Độ chính xác Suy luận Nhận thức Tầng 2 và Ánh xạ Tri thức	26
4.4 An toàn Đối kháng, Prompt Injection và Kiểm toán HMAC	27
4.5 Thử nghiệm Ablation, So sánh Tổng hợp và Độ bền Vận hành	27

5	Kết luận và Hướng phát triển	29
5.1	Tổng hợp Kết quả Nghiên cứu Đạt được	29
5.2	Đóng góp Khoa học và Thực tiễn	30
5.3	Các Giới hạn Hiện hữu	31
5.4	Hướng Phát triển Tương lai	32
	Tài liệu tham khảo	34

Danh sách hình vẽ

Hình 1.	Luồng thực thi vận hành trong pipeline SENTINEL. (Nguồn: Tác giả)	18
---------	---	----

Danh sách bảng

Bảng 1.	Bảng so sánh đối chiếu giữa SENTINEL và các giải pháp phòng thủ hiện hành	16
Bảng 2.	Cấu hình Môi trường Thực nghiệm và Đặc tả Tập Dữ liệu Giám sát	25
Bảng 3.	Độ trễ Suy luận và Tỷ lệ Giảm tải Nhiễu tại Tầng 1	26
Bảng 4.	Chỉ số Đánh giá Độ chính xác Suy luận Tầng 2 và Khung RAG . . .	26
Bảng 5.	So sánh Đối chứng Ablation và Các Nền tảng Tác tử An ninh Tiên tiến	28

Danh mục các từ viết tắt

Từ viết tắt	Định nghĩa đầy đủ
AI	Artificial Intelligence (Trí tuệ nhân tạo)
APT	Advanced Persistent Threat (Mối đe dọa thường trực nâng cao)
CTI	Cyber Threat Intelligence (Tình báo mối đe dọa mạng)
DAPT	Dynamic Advanced Persistent Threat (Tấn công APT động)
FAISS	Facebook AI Similarity Search (Cỗ máy tìm kiếm tương đồng FAISS)
FPR	False Positive Rate (Tỷ lệ báo động giả)
GGUF	GPT-Generated Unified Format (Định dạng hợp nhất GGUF)
HITL	Human-in-the-Loop (Con người trong vòng lặp)
HMAC	Hash-based Message Authentication Code (Mã xác thực thông điệp dựa trên hàm băm)
LLM	Large Language Model (Mô hình ngôn ngữ lớn)
MITRE ATT&CK	MITRE Adversarial Tactics, Techniques, and Common Knowledge (Khung tri thức chiến thuật và kỹ thuật tấn công MITRE)
NIST	National Institute of Standards and Technology (Viện Tiêu chuẩn và Công nghệ Quốc gia Hoa Kỳ)
RAG	Retrieval-Augmented Generation (Sinh văn bản tăng cường truy xuất)
RRF	Reciprocal Rank Fusion (Tổng hợp xếp hạng nghịch đảo)
SIEM	Security Information and Event Management (Quản lý thông tin và sự kiện an ninh)
SOAR	Security Orchestration, Automation, and Response (Điều phối, tự động hóa và phản hồi an ninh)
SOC	Security Operations Center (Trung tâm điều hành an ninh mạng)

Chương 1

Giới thiệu

Chương này trình bày bối cảnh nghiên cứu, bài toán trung tâm và cơ sở thiết kế hệ thống SENTINEL—một kiến trúc nhận thức hai tầng hướng tới tự động hóa quy trình phát hiện và phản hồi sự cố trong các Trung tâm Điều hành An ninh (SOC). Bằng việc phân tích các hạn chế của phương pháp phòng thủ tắt định truyền thống, tình trạng quá tải cảnh báo, cùng rào cản độ trễ và lỗ hổng an ninh đối kháng khi ứng dụng Mô hình Ngôn ngữ Lớn (LLM), chương này xác lập mục tiêu nghiên cứu, hệ thống câu hỏi nghiên cứu, phạm vi giới hạn, phương pháp luận Khoa học Thiết kế và các đóng góp cốt lõi của luận văn.

1.1 Bối cảnh và Động lực Nghiên cứu

Sự gia tăng quy mô hạ tầng CNTT doanh nghiệp cùng sự phức tạp của các hình thức tấn công mạng đa véc-tơ đang tạo ra thách thức lớn đối với công tác giám sát an toàn thông tin. Tại các Trung tâm Điều hành An ninh (SOC), hệ thống Quản lý Thông tin và Sự kiện An ninh (SIEM) phải thu thập và xử lý hàng triệu sự kiện nhật ký (telemetry) mỗi ngày [2]. Phương thức phòng thủ truyền thống dựa vào các thiết bị lọc ranh giới với tập luật tĩnh hoặc chữ ký cố định thể hiện sự hạn chế trước các kỹ thuật ẩn náu và biến thể tấn công mới. Để giảm thiểu rủi ro bỏ lọt mối đe dọa, các cấu hình an ninh thường được hạ thấp ngưỡng nhạy cảm, dẫn đến tình trạng quá tải thông báo với tỷ lệ báo động giả vượt quá 80% [4]. Hệ quả là các chuyên gia phân tích bị kiệt sức nhận thức (alert fatigue), làm suy giảm nghiêm trọng khả năng phát hiện các hành vi xâm nhập nguy hiểm. Đồng thời, các giải pháp Điều phối, Tự động hóa và Phản hồi An ninh (SOAR) hiện hành vận hành theo kịch bản cố định, hoàn toàn thiếu khả năng suy luận ngữ cảnh thích ứng [5].

Ứng dụng Mô hình Ngôn ngữ Lớn (LLM) mở ra hướng đi triển vọng trong việc tự động hóa quá trình tổng hợp và suy luận ngữ cảnh an ninh. Tuy nhiên, việc đưa LLM vào luồng xử lý dữ liệu mạng thực tế đối mặt với ba rào cản kỹ thuật cốt lõi: Thứ nhất, độ trễ tính toán của cơ chế tự chú ý (self-attention) kéo dài từ 4 đến 26 giây cho mỗi sự kiện, gây ra nghẽn luồng dữ liệu ở tốc độ đường truyền [18]. Thứ hai, nguy cơ an ninh đối kháng từ các

kỹ thuật tiêm nhiễm câu lệnh (prompt injection) thông qua dữ liệu nhật ký thô nhằm thao túng tiến trình suy luận của mô hình [9]. Thứ ba, các quy định nghiêm ngặt về chủ quyền dữ liệu và mô hình an ninh Zero-Trust cấm truyền xuất dữ liệu nhật ký nội bộ lên các dịch vụ AI đám mây thương mại, đòi hỏi mô hình phải vận hành hoàn toàn cục bộ trên hạ tầng phần cứng giới hạn [31]. Nhằm giải quyết các rào cản trên, nghiên cứu này đề xuất kiến trúc SENTINEL kết hợp bộ lọc thống kê $O(1)$ và Cổng Học máy LightGBM ở Tầng 1 với hệ thống tác tử AI suy luận ở Tầng 2, được bảo vệ bằng rào chắn mật mã và chuỗi niêm phong kiểm toán HMAC.

1.2 Mục tiêu Nghiên cứu

Mục tiêu tổng quát của luận văn là nghiên cứu thiết kế, xây dựng nguyên mẫu và đánh giá thực nghiệm kiến trúc SENTINEL nhằm tự động hóa quy trình phát hiện, suy luận ngữ cảnh và phản hồi sự cố an ninh mạng trên hạ tầng cục bộ, đạt tối ưu về độ trễ xử lý và đảm bảo an toàn mật mã.

Mục tiêu tổng quát trên được cụ thể hóa thông qua ba nhiệm vụ nghiên cứu trọng tâm: Thứ nhất, xây dựng đường ống lọc hai chặng phi trạng thái tại Tầng 1 vận hành ở tốc độ đường truyền, kết hợp thuật toán thống kê Welford $O(1)$, Cổng Học máy LightGBM và bộ đệm Semantic Cache Tầng 1.75 nhằm phân loại và cắt giảm tối thiểu 80% lưu lượng cảnh báo rõ ràng mà không tiêu tốn tài nguyên GPU. Thứ hai, thiết kế cơ chế bảo vệ tất định cho mô hình ngôn ngữ Tầng 2 thông qua kỹ thuật Đóng gói Dữ liệu Phân định sử dụng Nonce mật mã ngẫu nhiên, rào chắn Guardrail kiểm soát danh mục hành động đầu ra và chuỗi niêm phong HMAC-SHA256 nhằm vô hiệu hóa các cuộc tấn công tiêm nhiễm câu lệnh và đảm bảo tính chống chối bỏ của vết pháp y. Thứ ba, phát triển cỗ máy suy luận có trạng thái dựa trên đồ thị tác tử LangGraph kết hợp Bộ nhớ Đề dọa bền vững và hệ thống RAG kép (FAISS và BM25) tích hợp tri thức MITRE ATT&CK chuẩn STIX, cho phép sinh phán quyết minh bạch, phát hiện và vô hiệu hoá hư cấu bằng rào chắn neo-RAG tất định và hỗ trợ tương quan các chuỗi sự kiện xâm nhập phức tạp.

1.3 Câu hỏi Nghiên cứu

Tiến trình thiết kế và đánh giá thực nghiệm của luận văn được dẫn dắt bởi ba câu hỏi nghiên cứu chiến lược:

Câu hỏi nghiên cứu thứ nhất về hiệu năng đường ống và kinh tế học tầng lọc: Đường ống lọc lai Tầng 1 (kết hợp bộ lọc thống kê Welford $O(1)$, Cổng Học máy LightGBM và Bộ đệm Semantic Cache Tầng 1.75) đạt tỷ lệ tự động xả tải bao nhiêu phần trăm trên luồng nhật ký an ninh ở tốc độ đường truyền, và mức độ rút ngắn độ trễ phản hồi tổng thể của hệ

thông đạt được là bao nhiêu so với phương thức xử lý thuần mô hình ngôn ngữ?

Câu hỏi nghiên cứu thứ hai về rào chắn an ninh AI và tính toàn vẹn vết pháp y: Cơ chế Đóng gói Dữ liệu Phân định sử dụng Nonce mật mã ngẫu nhiên kết hợp với Rào chắn Guardrail tất định vô hiệu hóa ở mức độ nào các véc-tơ tấn công tiêm nhiễm câu lệnh qua dữ liệu nhật ký thô, và chuỗi niêm phong mật mã HMAC bảo vệ tính chống chối bỏ của vết pháp y ra sao trước nguy cơ bị thao túng nhật ký?

Câu hỏi nghiên cứu thứ ba về suy luận tác tử có trạng thái và quy kết kỹ thuật: Khung tác tử AI Tầng 2 có trạng thái khi được tích hợp Bộ nhớ Đe dọa bền vững và cơ chế RAG kép mang lại hiệu quả ra sao trong việc tương quan các sự kiện xâm nhập phức tạp, quy kết chính xác mã kỹ thuật theo chuẩn MITRE ATT&CK và sinh căn cứ giải thích pháp y minh bạch?

1.4 Phạm vi và Đối tượng Nghiên cứu

Đối tượng nghiên cứu trọng tâm của luận văn là Kiến trúc Nhận thức Hai tầng SENTINEL, bao gồm bộ lọc phi trạng thái Tầng 1 (thuật toán thống kê trực tuyến Welford và Cổng Học máy LightGBM), Tầng 1.75 Semantic Cache, cỗ máy tác tử có trạng thái Tầng 2 (đồ thị LangGraph và mô hình ngôn ngữ Foundation-Sec-8B-Instruct lượng tử hóa Q4_K_M vận hành qua llama.cpp), hệ thống RAG kép (kết hợp FAISS và BM25) tích hợp tri thức MITRE ATT&CK, cùng các cơ chế an ninh mật mã gồm Đóng gói Dữ liệu Phân định Nonce và chuỗi niêm phong kiểm toán HMAC-SHA256.

Phạm vi đánh giá thực nghiệm được giới hạn trên các tập dữ liệu benchmark chuẩn quốc tế: CSE-CIC-IDS2018 đại diện cho luồng dữ liệu giám sát mạng diện rộng, CSIC 2010 đại diện cho các cuộc tấn công HTTP Tầng 7 thực tế đánh vào ứng dụng thương mại điện tử, và DAPT2020 đại diện cho chuỗi sự kiện xâm nhập phức tạp APT. Toàn bộ hệ thống được triển khai và kiểm thử trên một máy trạm GPU cá nhân trang bị card đồ họa NVIDIA RTX 4060 Ti 16GB VRAM, vi xử lý Intel Core i7 và 32GB RAM, vận hành hoàn toàn cục bộ và cách ly mạng nhằm đáp ứng các quy định về chủ quyền dữ liệu. Danh mục hành động phản hồi tự động được giới hạn ở các chính sách chặn địa chỉ IP, ghi nhật ký giám sát hoặc chuyển chuyên gia an ninh duyệt; các thao tác can thiệp ngắt kết nối hạ tầng vật lý bị loại trừ khỏi phạm vi nghiên cứu này.

1.5 Phương pháp Nghiên cứu

Luận văn áp dụng phương pháp Nghiên cứu Khoa học Thiết kế (Design Science Research - DSR) kết hợp giữa xây dựng mô hình lý thuyết và kiểm chứng thực nghiệm định lượng. Tiến trình nghiên cứu được triển khai đồng bộ trên ba bình diện chính: Bình diện thống kê

và học máy kết hợp thuật toán Welford trực tuyến $O(1)$ để tính độ lệch Z -score với mô hình phân loại LightGBM cùng các thuật toán đo lường tần suất và phân bố lưu lượng. Bình diện logic tác tử mô hình hóa đồ thị trạng thái LangGraph điều phối suy luận ngôn ngữ, kết hợp các phương pháp định lượng truy xuất tri thức lai gồm tìm kiếm vector FAISS, tìm kiếm từ khóa thừa BM25 và hợp nhất xếp hạng RRF. Bình diện bảo mật đối kháng thử nghiệm ứng suất chống tiêm nhiễm câu lệnh và kiểm tra tính chống chối bỏ của vết nhật ký.

Hiệu quả của kiến trúc được đánh giá định lượng toàn diện thông qua Khung chỉ số 5 chiều (5D Metrics Framework) bao gồm: độ chính xác phân loại (Precision, Recall, F1), hiệu năng xử lý (độ trễ ms và tỷ lệ tự động giảm tải %), khả năng chống tấn công lừa AI, độ nhất quán của căn cứ giải thích pháp y do mô hình độc lập chấm điểm, và tính toàn vẹn vết nhật ký qua chuỗi niêm phong mật mã. Các thử nghiệm bóc tách (ablation studies) có kiểm soát được thực hiện nhằm đo lường và cô lập đóng góp riêng biệt của từng thành phần trong hệ thống tổng thể.

1.6 Đóng góp Cốt lõi của Luận văn

Luận văn đóng góp ba giá trị cốt lõi vào lĩnh vực an toàn thông tin và ứng dụng trí tuệ nhân tạo.

Về mặt kiến trúc hệ thống, nghiên cứu đề xuất và chứng minh tính hiệu quả của Kiến trúc Nhận thức Hai tầng SENTINEL. Việc kết hợp bộ lọc thống kê $O(1)$ và Cổng Học máy tại Tầng 1 giúp giải quyết tự chủ phần lớn lưu lượng ở tốc độ đường truyền với độ trễ ở mức mili-giây, kết hợp với Tầng 1.75 Semantic Cache xử lý các sự kiện trùng lặp, giải quyết dứt điểm nút thắt cổ chai độ trễ và triệt tiêu nguy cơ quá tải tài nguyên tính toán.

Về mặt bảo mật AI, nghiên cứu đóng góp cơ chế phòng thủ mang tính cấu trúc dựa trên kỹ thuật Đóng gói Dữ liệu Phân định sử dụng Nonce mật mã ngẫu nhiên và rào chắn Guardrail tất định. Cơ chế này đem lại bảo chứng an ninh kiến trúc, vô hiệu hóa hoàn toàn các cuộc tấn công tiêm nhiễm câu lệnh qua luồng dữ liệu thô mà không phụ thuộc vào các bộ phân loại ngữ nghĩa xác suất vốn dễ bị vượt qua. Đồng thời, chuỗi mã hóa HMAC-SHA256 đảm bảo tính chống chối bỏ cho toàn bộ vết pháp y.

Về mặt tác tử và tri thức bảo mật, nghiên cứu thay thế các kịch bản SOAR cứng nhắc bằng đồ thị tác tử có trạng thái LangGraph kết nối với kho tri thức 432 mục MITRE ATT&CK chuẩn STIX và Bộ nhớ Đe dọa bền vững. Giải pháp cho phép tự động phát hiện các sự kiện xâm nhập phức tạp và sinh căn cứ giải thích pháp y chuẩn xác, vận hành trơn tru trên hạ tầng GPU thương mại phổ thông.

1.7 Cấu trúc của Luận văn

Nội dung còn lại của luận văn được tổ chức thành bốn chương tiếp theo. Chương 2 hệ thống hóa cơ sở lý thuyết về thống kê Welford, mô hình LightGBM, lượng tử hóa mô hình ngôn ngữ lớn, đồ thị tác tử LangGraph, hệ thống RAG kép, mật mã học kiểm toán nhật ký và tổng quan các công trình nghiên cứu liên quan. Chương 3 trình bày chi tiết thiết kế kỹ thuật của hệ thống SENTINEL, bao gồm bộ lọc hai tầng, Cổng Học máy, máy trạng thái tác tử, cơ chế đóng gói bảo mật và bảng điều khiển SOC. Chương 4 trình bày kết quả thực nghiệm định lượng trên các tập dữ liệu benchmark chuẩn, các phân tích bóc tách thành phần và kiểm chứng an ninh đối kháng. Cuối cùng, Chương 5 tổng kết các kết quả đạt được, thừa nhận giới hạn nghiên cứu và phác thảo hướng phát triển trong tương lai.

Chương 2

Cơ sở Lý thuyết và Tổng quan Nghiên cứu

Chương này trình bày tóm lược cơ sở lý thuyết nền tảng và tổng quan nghiên cứu liên quan. Nội dung tập trung phân tích nút thắt vận hành an ninh, cơ sở thống kê và học máy Tầng 1, kiến trúc tác tử và ngôn ngữ lớn Tầng 2, các nguy cơ an ninh đối kháng AI cùng kỹ thuật kiểm toán mật mã, và đặc biệt đi sâu khảo sát các hệ thống AI Security hiện hành nhằm xác định rõ khoảng trống nghiên cứu mà hệ thống SENTINEL giải quyết.

2.1 Thực trạng Vận hành SOC và Nút thắt Nhận thức

Công tác giám sát an toàn thông tin tại các Trung tâm Điều hành An ninh (SOC) dựa trên việc thu thập nhật ký từ NGFW, IDS/IPS và EDR về hệ thống SIEM tập trung [2]. Khối lượng nhật ký khổng lồ từ hạ tầng phân tán vượt quá khả năng phân tích thủ công [3]. Do các thiết bị phòng thủ ranh giới vận hành dựa trên chữ ký tĩnh và tập luật tắt định, việc nổi lỏng ngưỡng cảnh báo để tránh bỏ lọt đe dọa đã dẫn tới cuộc khủng hoảng quá tải thông báo với tỷ lệ báo động giả vượt quá 80% [4], gây ra kiệt sức nhận thức (alert fatigue) cho chuyên gia phân tích. Dù giải pháp SOAR giúp tự động hóa phản hồi, hệ thống này phụ thuộc vào các kịch bản (playbooks) lập trình sẵn cố định, hoàn toàn thiếu khả năng suy luận ngữ cảnh trước các biến thể tấn công mới [5].

2.2 Lý thuyết Thống kê Trực tuyến và Học máy Tầng 1

Để lọc luồng dữ liệu ở tốc độ đường truyền mà không lưu trữ toàn bộ lịch sử trong bộ nhớ, thuật toán thống kê trực tuyến Welford đạt độ phức tạp $\mathcal{O}(1)$ về thời gian và không gian [6]. Giá trị trung bình μ_k và tổng bình phương độ lệch S_k được cập nhật theo công thức truy hồi:

$$\mu_k = \mu_{k-1} + \frac{x_k - \mu_{k-1}}{k}, \quad S_k = S_{k-1} + (x_k - \mu_{k-1})(x_k - \mu_k) \quad (2.1)$$

cho phép tính toán độ lệch chuẩn $\sigma_k = \sqrt{S_k/(k-1)}$ và Z-score dị thường liên tục. Song song với đó, mô hình LightGBM với cơ chế phát triển cây theo lá (leaf-wise) đạt tốc độ

suy luận dưới 0.35 ms trên mỗi mẫu. Để chống kỹ thuật né tránh học máy (anti-evasion), Cổng Học máy thực hiện kẹp ngưỡng Z -score trong khoảng $\pm 8\sigma$ và điền giá trị thiếu bằng trung bình đặc trưng. Ngoài ra, cơ chế Semantic Cache Tầng 1.75 sử dụng kỹ thuật băm cấu trúc mẫu dữ liệu trong RAM giúp truy xuất và phản hồi các tấn công lặp lại (DDoS, Brute-force) trong 1 ms, ngắt luồng xử lý trước khi kích hoạt GPU.

2.3 Mô hình Ngôn ngữ Lớn Cục bộ và Trí tuệ Tác tử Tầng 2

Triển khai LLM cục bộ đòi hỏi tối ưu hóa bộ nhớ nghiêm ngặt: mô hình Foundation-Sec-8B-Instruct ở định dạng FP16 chiếm xấp xỉ 18 GB VRAM [23]. Kỹ thuật lượng tử hóa ánh xạ trọng số thực sang lưới số nguyên bit thấp [19]. Thông qua định dạng GGUF Q4_K_M trên llama.cpp, bộ nhớ VRAM yêu cầu giảm xuống 7–8 GB ($>50\%$) mà không làm giảm đáng kể độ chính xác, vận hành trơn tru trên card GPU 16 GB. Để điều phối quy trình suy luận, Tầng 2 sử dụng đồ thị trạng thái không chu trình (Acyclic State-Graph) LangGraph [8] tích hợp Bộ nhớ Đe dọa (Threat Memory) lưu trữ lịch sử xâm nhập để liên kết các hành vi đơn lẻ. Nhằm chống hư cấu (hallucination), hệ thống tích hợp Retrieval-Augmented Generation (RAG) [7] theo mô hình Dual-RAG kết hợp tìm kiếm ngữ nghĩa FAISS [20] và từ khóa BM25 [21], được hợp nhất bằng thuật toán Reciprocal Rank Fusion (RRF) [11]:

$$RRF_Score(d) = \sum_{m \in M} \frac{1}{k + r_m(d)} \quad (2.2)$$

truy xuất trực tiếp từ 433 mục STIX MITRE ATT&CK và tài liệu NIST SP 800-61r2 làm căn cứ giải trình pháp y.

2.4 An ninh Đối kháng AI và Mật mã học Kiểm toán Nhật ký

Tích hợp LLM phát sinh nguy cơ bị tấn công tiêm nhiễm câu lệnh qua nhật ký (log-substrate prompt injection) [9], khi kẻ tấn công chèn câu lệnh độc hại vào chuỗi User-Agent hoặc tham số URI để thao túng suy luận của AI [30]. Để triệt tiêu véc-tơ này, SENTINEL áp dụng cơ chế Đóng gói Dữ liệu Phân định (Delimited Data Encapsulation) với Nonce ngẫu nhiên cô lập dữ liệu thô, kết hợp rào chắn Guardrail tắt định ép đầu ra mô hình nghiêm ngặt trong 3 trạng thái (BLOCK_IP, LOG, AWAIT_HITL). Nhằm đảm bảo tính chống chối bỏ cho vết pháp y, hệ thống áp dụng kỹ thuật HMAC-SHA256 [29] niêm phong từng bản ghi nhật ký bằng khóa bí mật cục bộ, tạo thành chuỗi kiểm toán chống thao túng sau xâm nhập.

2.5 Tổng quan Nghiên cứu Liên quan và Khoảng trống Nghiên cứu

Nghiên cứu ứng dụng trí tuệ nhân tạo trong vận hành an ninh mạng (SOC) đã tiến triển qua bốn nhóm giải pháp kiến trúc chính, từ các hệ thống tất định truyền thống đến các nền tảng tác tử AI tự chủ hiện đại [15]. Việc phân tích chuyên sâu công nghệ, mục tiêu và hạn chế cốt lõi của từng nhóm nghiên cứu là cơ sở xác định khoảng trống kỹ thuật mà hệ thống SENTINEL giải quyết.

Nhóm giải pháp phòng thủ doanh nghiệp truyền thống bao gồm các nền tảng SIEM thương mại như IBM QRadar và giải pháp SOAR như Palo Alto Cortex XSOAR [2, 5]. IBM QRadar thu thập và tương quan sự kiện bằng các tập luật tĩnh (correlation rules) trên cơ sở dữ liệu tập trung. Tuy nhiên, QRadar bộc lộ hạn chế lớn về tỷ lệ báo động giả cao ($>80\%$) do thiếu khả năng hiểu ngữ cảnh tổng thể. Để khắc phục, Cortex XSOAR tự động hóa quy trình phản hồi bằng các kịch bản lập trình sẵn (playbooks bằng Python/JavaScript). Mặc dù giảm tải tác vụ lặp lại, Cortex XSOAR vận hành hoàn toàn tất định và cứng nhắc: khi gặp các biến thể tấn công mới có chuỗi payload nguy trang hoặc hành vi bất thường nằm ngoài kịch bản đã định nghĩa, hệ thống lập tức thất bại hoặc bỏ sót đe dọa.

Nhóm tác tử AI đám mây tiêu biểu là Watchtower [12] và CyberRAG [13]. Watchtower đề xuất kiến trúc đa tác tử phối hợp điều phối quy trình điều tra sự cố an ninh bằng cách gửi luồng nhật ký tới các LLM đám mây (như GPT-4, Claude). Tuy nhiên, việc đẩy trực tiếp toàn bộ dữ liệu nhật ký thô lên mô hình ngôn ngữ lớn đám mây gây ra hai hạn chế nghiêm trọng: độ trễ tự chú ý bậc hai $\mathcal{O}(N^2)$ khiến thời gian xử lý mỗi sự kiện kéo dài từ 4 đến 26 giây, gây tắc nghẽn hoàn toàn đường ống dữ liệu; đồng thời vi phạm nghiêm trọng nguyên tắc Zero-Trust và chủ quyền dữ liệu doanh nghiệp [31]. Trong khi đó, CyberRAG [13] tập trung truy xuất tri thức đe dọa (CTI) bằng RAG đơn tầng; hệ thống này thiếu bộ lọc đường truyền Tầng 1 nên dễ bị quá tải khi dòng sự kiện đạt hàng trăm ngàn log/giây, đồng thời thiếu cơ chế tác tử có trạng thái để liên kết chuỗi tấn công đa giai đoạn.

Nhóm tác tử tự chủ hoạch định và suy luận an ninh bao gồm AutoBNB [14], LanG Agentic SOC [16] và Policy-Guided SIEM [17]. AutoBNB kết hợp mạng Bayes với tác tử hoạch định (planning agents) để quy kết nguồn gốc xâm nhập, nhưng gặp hạn chế lớn về chi phí tính toán đồ thị và thiếu cơ chế chống tiêm nhiễm prompt qua dữ liệu nhật ký [9]. Gần đây nhất, nền tảng LanG [16] đề xuất mô hình tác tử AI chú trọng cơ chế quản trị (governance-aware) và Policy-Guided SIEM [17] tích hợp rào chắn quy tắc với hệ thống SIEM Splunk. Mặc dù các nghiên cứu này đạt được bước tiến trong việc điều phối đa tác tử và triệt tiêu một phần hư cấu ngôn ngữ, chúng vẫn vận hành theo kiến trúc đơn tầng (Single-Tier/Multi-Agent), nơi mọi sự kiện mạng đều phải vượt qua các nút suy luận LLM phức tạp. Do đó, độ trễ trung bình của hệ thống vẫn duy trì ở mức cao từ 480 ms đến 520 ms, đồng thời đòi hỏi hạ tầng phần cứng đa GPU tốn kém (16 GB–24 GB VRAM), hoàn toàn không thể đáp ứng yêu cầu xả tải ở tốc độ đường truyền ngay tại Tầng 1.

Khoảng trống nghiên cứu cốt lõi được xác định là: Hiện chưa có một kiến trúc lai nào giải quyết đồng thời ba thách thức: (1) Lọc dữ liệu tốc độ đường truyền ở Tầng 1 để loại bỏ tối thiểu 80% lưu lượng nhiễu với độ trễ dưới 1 ms; (2) Suy luận nhận thức Tầng 2 bằng AI Tác tử có trạng thái chạy cục bộ (Air-gapped GPU 16 GB) loại bỏ hư cấu bằng Dual-RAG; và (3) Bảo vệ toàn vẹn mô hình AI bằng đóng gói phân định Nonce mật mã cùng niêm phong vết pháp y HMAC-SHA256. Bảng 1 đối chiếu chi tiết SENTINEL với các công trình đại diện.

Bảng 1. Bảng so sánh đối chiếu giữa SENTINEL và các giải pháp phòng thủ hiện hành

Tiêu chí Đánh giá	SIEM / SOAR (QRadar, XSOAR)	Tác tử SOTA (Watchtower, LanG, AutoBnB)	Kiến trúc SENTINEL (Luận văn)
Kỹ thuật Cốt lõi	Tập luật tương quan tĩnh, kịch bản Python/JS cứng	Đa tác tử LLM Đám mây / Local Multi-Agent	Bộ lọc Welford $\mathcal{O}(1)$ + LightGBM T1, LangGraph Agent T2
Mục tiêu Vận hành	Gom nhật ký tập trung và phản hồi theo kịch bản	Tự động hóa điều tra sự cố bằng suy luận ngôn ngữ	Lọc loại nhiễu đường truyền tốc độ cao và suy luận nhận thức cục bộ
Độ trễ & Tải luồng	Rất thấp (< 1 ms) nhưng quá tải báo động giả	Trung bình/Cao (480 ms–26 s), gây nghẽn đường ống	Tối ưu (< 0.40 ms Tầng 1, 1 ms Cache, giảm > 80% tải cho T2)
Chủ quyền Dữ liệu	Cục bộ nội bộ	Rủi ro rò rỉ Cloud hoặc ngôn 24GB GPU	Bảo mật tuyệt đối, chạy 100% Air-gapped trên GPU 16 GB
Chống Prompt Inj.	Không áp dụng	Phụ thuộc bộ lọc xác suất (dễ bị bẻ khóa)	Bảo chứng an ninh kiến trúc (Delimited Nonce Encapsulation)
Kiểm toán Pháp y	Nhật ký văn bản tiêu chuẩn (dễ bị chỉnh sửa)	Không hỗ trợ niêm phong mật mã vết pháp y	Chuỗi mã hóa HMAC-SHA256 niêm phong chống chối bỏ

Chương 3

Thiết kế Hệ thống và Triển khai Kỹ thuật

Chương này trình bày chi tiết thiết kế kiến trúc và giải pháp triển khai kỹ thuật của hệ thống SENTINEL. Nội dung tập trung phân tích luồng xử lý phân tầng, bộ lọc đường truyền Tầng 1 cùng Cổng Học máy, kiến trúc suy luận tác tử Tầng 2 và Bộ nhớ Đe dọa, cơ chế truy xuất tri thức Dual-RAG, giải pháp an ninh đối kháng AI cùng kỹ thuật kiểm toán mật mã, và phương án triển khai bảng điều khiển an ninh cục bộ.

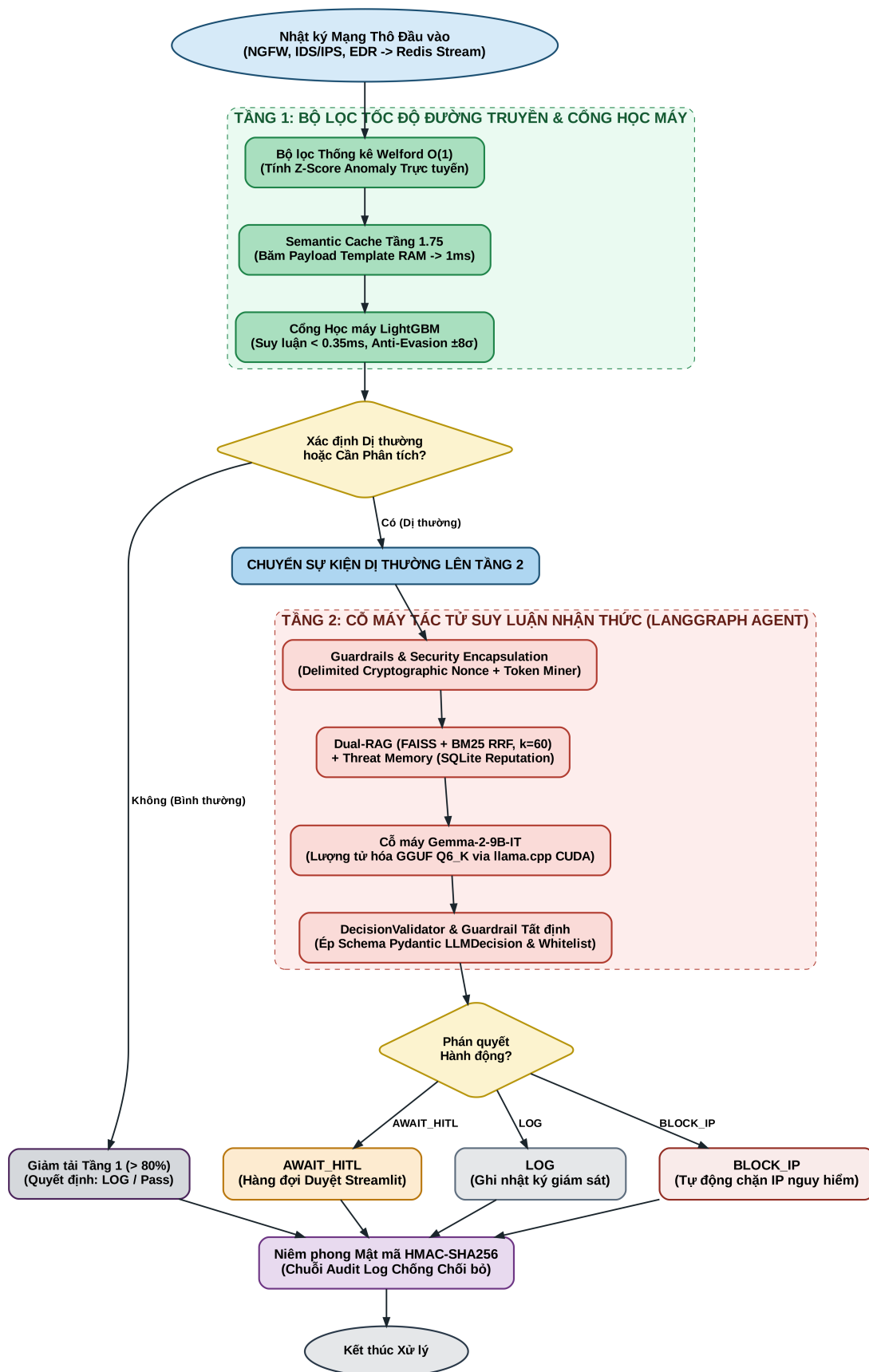
3.1 Kiến trúc Tổng thể SENTINEL và Tích hợp Ngăn xếp SOC

Để bảo vệ hạ tầng mạng doanh nghiệp trước luồng dữ liệu giám sát mật độ cao mà không gây nghẽn đường ống xử lý, hệ thống SENTINEL áp dụng Kiến trúc Nhận thức Hai tầng (Two-Tier Cognitive Architecture). Nguyên lý thiết kế cốt lõi là phân tách triệt để nhiệm vụ tính toán: Tầng 1 vận hành các thuật toán thống kê và học máy phi trạng thái để sàng lọc và loại bỏ tối thiểu 80% lưu lượng nhiễu ở tốc độ đường truyền; Tầng 2 vận hành cỗ máy tác tử ngôn ngữ có trạng thái nhằm suy luận ngữ cảnh sâu và đưa ra phán quyết phản hồi cho các sự kiện dị thường phức tạp.

Hình 1 minh họa luồng thực thi vận hành chi tiết trong đường ống dữ liệu của SENTINEL. Luồng nhật ký mạng thô phát sinh từ các nguồn giám sát ranh giới (NGFW, IDS/IPS, EDR) được ingesting vào hàng đợi trung chuyển Redis Stream.

Chỉ những sự kiện bị xác định là dị thường mới được chuyển tiếp lên Tầng 2. Tại đây, cỗ máy tác tử LangGraph kích hoạt chuỗi suy luận bằng mô hình Foundation-Sec-8B-Instruct cục bộ, kết hợp dữ liệu lịch sử từ Bộ nhớ Đe dọa và tri thức truy xuất từ hệ thống Dual-RAG. Phán quyết cuối cùng được kiểm soát bởi lớp rào chắn tắt định, giới hạn nghiêm ngặt trong ba trạng thái hợp lệ (BLOCK_IP, LOG, hoặc AWAIT_HITL). Mọi bản ghi kết quả đều trải qua bước niêm phong mật mã bằng hàm HMAC-SHA256 nhằm bảo vệ tính toàn vẹn và chống chối bỏ cho vết pháp y.

Trong kiến trúc SOC doanh nghiệp hiện đại, SENTINEL đóng vai trò middleware nhận thức thông minh đứng trung gian kết nối giữa nền tảng thu thập nhật ký SIEM (như IBM



Hình 1. Luồng thực thi vận hành trong pipeline SENTINEL. (Nguồn: Tác giả)

QRadar) với công cụ thực thi tường lửa và tự động hóa SOAR (như Palo Alto Cortex XSOAR). Bằng cách xử lý lượng lớn dữ liệu nhiễu ngay tại Tầng 1 và cung cấp căn cứ giải trình rõ ràng cho các sự kiện leo thang ở Tầng 2, SENTINEL triệt tiêu cuộc khủng hoảng quá tải thông báo giả cho chuyên gia an ninh, đồng thời bảo đảm chủ quyền dữ liệu tuyệt đối nhờ khả năng vận hành air-gapped hoàn toàn trên hạ tầng GPU đơn 16 GB VRAM.

3.2 Tầng 1: Bộ lọc Tốc độ Đường truyền và Cổng Học máy

Tầng 1 đóng vai trò rào chắn phi trạng thái đầu tiên xử lý dữ liệu ở tốc độ đường truyền. Lớp này kết hợp bộ lọc thống kê đường cơ sở Welford $\mathcal{O}(1)$ và Cổng Học máy LightGBM nhằm đảm bảo độ trễ suy luận ở mức mili-giây và triệt tiêu lưu lượng nhiễu trước khi kích hoạt tài nguyên GPU.

Bộ lọc thống kê đường cơ sở tính toán độ lệch chuẩn σ và điểm Z -score theo thời gian thực đối với các đặc trưng lưu lượng (tần suất gói tin, dung lượng luồng, thời lượng kết nối). Điểm Z -score của thuộc tính x được xác định theo công thức $Z = (x - \mu)/\sigma$, với trung bình μ và độ lệch σ cập nhật liên tục qua thuật toán Welford không lưu trữ lịch sử thô [6]. Cụ thể, tại mỗi bước thời gian k , giá trị kỳ vọng μ_k và tổng bình phương độ lệch S_k được tính theo các công thức truy hồi:

$$\mu_k = \mu_{k-1} + \frac{x_k - \mu_{k-1}}{k}, \quad S_k = S_{k-1} + (x_k - \mu_{k-1})(x_k - \mu_k) \quad (3.1)$$

cho phép xác định độ lệch chuẩn $\sigma_k = \sqrt{S_k/(k-1)}$. Nhờ đó, bộ lọc lập tức loại bỏ các luồng lưu lượng tuân theo phân bố bình thường. Đối với các hành vi tấn công lặp lại diện rộng (như DDoS hoặc dò mật khẩu tự động), cơ chế Semantic Cache Tầng 1.75 băm cấu trúc mẫu dữ liệu trong bộ nhớ RAM, cho phép tái sử dụng phán quyết có sẵn và phản hồi trong 1 ms, ngắt hoàn toàn luồng xử lý trước khi dữ liệu đi sâu vào hệ thống.

Cổng Học máy LightGBM được tích hợp ngay sau bộ lọc thống kê nhằm đánh giá các tương tác đặc trưng phi tuyến. Mô hình sử dụng cấu trúc cây quyết định tăng cường độ dốc với kỹ thuật phát triển theo lá (leaf-wise) và phân nhóm đặc trưng dạng biểu đồ tần suất (histogram), được huấn luyện trên 1 triệu mẫu lưu lượng NetFlow. Mỗi mẫu dữ liệu được Cổng ML đánh giá trong thời gian khoảng 0.35 ms. Nhằm triệt tiêu véc-tơ tấn công né tránh học máy (anti-evasion), Cổng ML thực hiện kẹp ngưỡng Z -score trong khoảng $\pm 8\sigma$ và tự động điền các giá trị thiếu bằng trung bình đặc trưng baseline. Nếu tỷ lệ đặc trưng bị biến dạng vượt quá 30%, Cổng ML tự động từ chối phán quyết và nâng cấp sự kiện lên Tầng 2 để phân tích ngữ cảnh chuyên sâu.

3.3 Tầng 2: Tác tử Nhận thức LangGraph và Bộ nhớ Đe dọa

Tầng 2 đảm nhận nhiệm vụ suy luận nhận thức có trạng thái đối với các sự kiện dị thường được chuyển lên từ Tầng 1. Cổ máy suy luận vận hành mô hình ngôn ngữ Foundation-Sec-8B-Instruct lượng tử hóa định dạng GGUF Q4_K_M [23] thông qua thư viện llama.cpp với cờ tối ưu hóa CUDA trên GPU cục bộ 16 GB VRAM. Kỹ thuật lượng tử hóa Q4_K_M giúp cắt giảm dung lượng bộ nhớ VRAM yêu cầu từ 18 GB (ở dạng FP16 gốc) xuống còn 7 đến 8 GB (giảm trên 50% tài nguyên) mà không làm suy giảm độ chính xác suy luận, bảo đảm cổ máy vận hành trơn tru trong môi trường cục bộ air-gapped.

Quy trình suy luận tác tử được điều phối bởi đồ thị LangGraph [8]. Luồng xử lý tuân theo chuỗi tất định qua 5 trạm chính: lọc rào chắn (guardrails), làm giàu ngữ cảnh (rag_context), phân loại sơ bộ (llm_triage), ánh xạ kỹ thuật (attack_mapper), và thực thi phán quyết (action_executor hoặc human_in_loop). Trong đó, trạm ánh xạ kỹ thuật đòi hỏi căn cứ xác thực từ kho tri thức chuẩn hóa; nếu không tìm thấy mã kỹ thuật phù hợp rõ ràng, đồ thị tự động định tuyến sự kiện sang trạm kiểm duyệt của chuyên gia (AWAIT_HITL) thay vì đưa ra phán quyết đoán mò. Danh mục hành động đầu ra của tác tử bị kiểm soát nghiêm ngặt trong ba trạng thái: BLOCK_IP, LOG, hoặc AWAIT_HITL.

Để liên kết các hành vi xâm nhập rải rác theo thời gian, Tầng 2 duy trì cơ chế Bộ nhớ Đe dọa (Threat Memory) trên cơ sở dữ liệu SQLite được tối ưu hóa chỉ mục. Kết nối SQLite được cấu hình ở chế độ synchronous=NORMAL và duy trì cơ chế rollback-journal thay cho chế độ WAL nhằm tránh lỗi xung đột quyền truy cập tệp khi vận hành trong môi trường Docker đa người dùng. Bộ nhớ Đe dọa quản lý cấu trúc bảng bao gồm lịch sử uy tín IP (ip_reputation), thực thể hợp pháp nội bộ (known_entities), chỉ báo rủi ro (apt_indicators), và sự kiện đe dọa (threat_events). Điểm uy tín S của địa chỉ IP suy giảm tự nhiên theo thời gian im lặng t theo công thức:

$$S_{\text{new}} = S_{\text{old}} \times (1 - \lambda)^t \quad (3.2)$$

với λ là hệ số suy giảm. Khi một địa chỉ IP tích lũy điểm uy tín đạt ngưỡng tối đa ($S = 100$), Tầng 1 tự động áp dụng cơ chế chặn ngay lập tức (block-on-sight) cho các kết nối tiếp theo mà không cần kích hoạt lại LLM Tầng 2, khép kín vòng phản hồi tự động. Ngược lại, các địa chỉ IP hạ tầng nội bộ (như 10.0.0.99) được thiết lập trong danh sách trắng (whitelist) cứng và miễn nhiễm tuyệt đối với lệnh chặn nhằm ngăn ngừa nguy cơ tự từ chối dịch vụ (self-DoS). Kỹ thuật này cho phép tác tử liên kết chính xác các chuỗi tấn công đa giai đoạn kéo dài qua nhiều ngày.

3.4 Cơ chế Truy xuất Tri thức Lai Dual-RAG

Để loại bỏ hoàn toàn hiện tượng hư cấu thông tin (hallucination) và bảo đảm tính minh bạch cho các quyết định phản hồi an ninh, Tầng 2 tích hợp cơ chế Truy xuất Tri thức Lai Dual-RAG. Mục tiêu của cơ chế này là cung cấp căn cứ pháp y chuẩn hóa từ các tài liệu chuẩn mực quốc tế cho mô hình ngôn ngữ lớn trong mỗi phiên suy luận.

Kho tri thức an ninh của SENTINEL được xây dựng từ 433 mục kỹ thuật tấn công MITRE ATT&CK [24] được cấu trúc hóa theo chuẩn STIX 2.1 cùng tài liệu hướng dẫn xử lý sự cố an ninh máy tính NIST SP 800-61r2 [10]. Quy trình truy xuất kết hợp song song hai phương pháp tìm kiếm bổ trợ nhau: truy xuất ngữ nghĩa mật độ cao bằng vector FAISS [20] và truy xuất từ khóa thưa bằng thuật toán BM25 [21]. Trong đó, phương pháp vector FAISS sử dụng mô hình Sentence-BERT [25] để biến đổi truy vấn sự kiện thành không gian nhúng đa chiều và tìm kiếm khoảng cách L2/Cosine, giúp phát hiện các kỹ thuật tấn công có cùng bản chất ngữ nghĩa nhưng khác biệt về từ khóa diễn đạt. Ngược lại, phương pháp BM25 tính toán tần suất từ khóa trên chỉ mục thưa, đảm bảo truy xuất chính xác các định danh kỹ thuật cụ thể như mã CVE, khóa Registry hoặc số hiệu cổng dịch vụ.

Kết quả trích xuất từ hai phương pháp được hợp nhất bằng thuật toán Reciprocal Rank Fusion (RRF) [11] theo định thức:

$$RRF_Score(d) = \sum_{m \in \{FAISS, BM25\}} \frac{1}{k + r_m(d)} \quad (3.3)$$

trong đó $r_m(d)$ biểu thị thứ hạng của tài liệu d trong phương pháp m và $k = 60$ là hằng số điều hòa. Danh sách các kỹ thuật có điểm số RRF cao nhất được nén và chèn trực tiếp vào ngữ cảnh prompt tại trạm `rag_context`. Nhờ đó, cỗ máy tác tử có thể liên kết chính xác sự kiện với mã kỹ thuật MITRE ATT&CK tương ứng, đồng thời trích dẫn căn cứ giải trình pháp y chuẩn mực cho phán quyết xử lý.

3.5 Kiến trúc An ninh AI và Niêm phong Kiểm toán Mật mã

Tích hợp các mô hình ngôn ngữ lớn vào hạ tầng an ninh mạng đòi hỏi giải pháp phòng thủ đôi kháng toàn diện chống lại nguy cơ tiêm nhiễm câu lệnh qua nhật ký (log-substrate prompt injection) [9]. Đây là kỹ thuật kẻ tấn công chèn các câu lệnh điều khiển độc hại vào bên trong các trường dữ liệu nhật ký thô (như User-Agent, URI, hoặc nội dung Syslog) nhằm đánh lừa và chiếm quyền điều khiển hành vi của mô hình ngôn ngữ.

Để triệt tiêu véc-tơ tấn công nguy hiểm này, SENTINEL áp dụng cơ chế Đóng gói Dữ liệu Phân định (Delimited Data Encapsulation) kết hợp ngẫu nhiên hóa mật mã duy nhất cho mỗi phiên xử lý [30]. Toàn bộ nội dung dữ liệu nhật ký thô được bọc hoàn toàn bên trong

cặp thẻ phân định chứa chuỗi nonce mật mã (ví dụ: «<DATA_HASH...>»). Cấu trúc đóng gói này buộc mô hình ngôn ngữ lớn phải xử lý toàn bộ dữ liệu bên trong như các văn bản dữ liệu thuần túy, loại bỏ khả năng kích hoạt các câu lệnh điều khiển ẩn danh. Đồng thời, hệ thống áp dụng cơ chế gỡ nhãn dữ liệu nhạy cảm (*label stripping*) đối với các thuộc tính phân loại nội bộ trước khi truyền vào prompt, ngăn ngừa nguy cơ rò rỉ thông tin trạng thái ra bên ngoài. Song song với đó, lớp rào chắn tất định kiểm soát chặt chẽ đầu ra, ép phán quyết của mô hình tuân thủ cấu trúc Pydantic schema (*LLMDecision*); trong trường hợp định dạng bị lỗi hoặc chứa dấu hiệu bất thường, cơ chế phục hồi tự động bằng Regex sẽ trích xuất dữ liệu cốt lõi hoặc tự động chuyển sự kiện về trạng thái an toàn *AWAIT_HITL*.

Bên cạnh giải pháp bảo vệ AI, SENTINEL tích hợp kỹ thuật niêm phong kiểm toán mật mã nhằm bảo đảm tính chống chối bỏ cho vết chứng cứ pháp y. Mỗi bản ghi sự kiện và phán quyết an ninh thứ i được liên kết chuỗi mật mã bằng thuật toán HMAC-SHA256 [29] theo định thức:

$$H_i = \text{HMAC-SHA256}(D_i \parallel H_{i-1}, K) \quad (3.4)$$

trong đó D_i đại diện cho dữ liệu bản ghi hiện tại, H_{i-1} là giá trị băm mật mã của bản ghi liền trước, và K là khóa bí mật cục bộ. Việc liên kết chuỗi băm tạo thành một chuỗi kiểm toán liên tục có khả năng chống sửa đổi tuyệt đối; bất kỳ hành vi xâm nhập trái phép nào nhằm thay đổi nội dung hoặc xóa bỏ bản ghi vết pháp y sẽ làm đứt gãy tính liên tục của chuỗi băm và bị hệ thống phát hiện tức thì.

3.6 SOC Dashboard và Kiến trúc Triển khai Cục bộ

Bảng điều khiển hoạt động an ninh SOC Analyst Dashboard được triển khai trên nền tảng ứng dụng Streamlit, kết nối trực tiếp với Redis Stream và cơ sở dữ liệu Bộ nhớ Đe dọa. Giao diện cung cấp cho chuyên gia an ninh góc nhìn vận hành thời gian thực: giám sát lưu lượng xử lý Tầng 1, biểu đồ dòng thời gian liên kết chuỗi tấn công đa giai đoạn, chỉ báo toàn vẹn của chuỗi niêm phong mật mã HMAC-SHA256, và bảng điều khiển kiểm duyệt người dùng HITL (*AWAIT_HITL*).

Hạ tầng hệ thống được đóng gói hoàn toàn trong các container Docker độc lập thông qua cấu hình `docker-compose.yml`. Thư viện suy luận `llama.cpp` được biên dịch với cờ CUDA nhằm khai thác tối đa sức mạnh tính toán song song trên card đồ họa NVIDIA RTX 4060 Ti 16 GB VRAM. Cơ sở dữ liệu Bộ nhớ Đe dọa `threat_memory.db` và chỉ mục vector FAISS được gắn kết trên các Docker Volume độc lập, bảo đảm điểm uy tín địa chỉ IP và vết chứng cứ pháp y sống sót qua các chu kỳ tái khởi động container.

Đặc biệt, thiết kế triển khai tuân thủ nghiêm ngặt chuẩn an toàn thông tin Zero Trust [31]: các chuỗi mật khẩu trong `REDIS_URL` được che phủ (`redact`) hoàn toàn trước khi ghi

log. Nhằm bảo đảm khả năng chịu tải khi xảy ra sự cố tăng đột biến lưu lượng (stream surge), hệ thống áp dụng cơ chế quản lý tải backpressure dựa trên độ trễ (lag) của Redis consumer group thay vì độ dài hàng đợi tĩnh, duy trì tính ổn định tuyệt đối cho toàn bộ hệ thống SOC hai tầng.

Chương 4

Thực nghiệm và Đánh giá

Chương này trình bày toàn bộ kết quả thực nghiệm và đánh giá định lượng đối với hệ thống SENTINEL. Nội dung được cô đọng nhằm tập trung phân tích các chỉ số cốt lõi: hiệu năng xả tải ở tốc độ đường truyền tại Tầng 1, độ chính xác suy luận tác tử và ánh xạ tri thức tại Tầng 2, năng lực phòng thủ đối kháng AI cùng tính toàn vẹn kiểm toán mật mã, kết hợp các phân tích Ablation đối chứng và so sánh đa chiều với các giải pháp tiên tiến (SOTA) hiện hữu.

4.1 Môi trường Thực nghiệm và Tập Dữ liệu Giám sát

Hệ thống SENTINEL được triển khai thử nghiệm trên môi trường máy chủ cục bộ đại diện cho trung tâm điều hành an ninh (SOC) doanh nghiệp vừa và nhỏ, trang bị bộ vi xử lý Intel Core i7, 32 GB RAM DDR5 và card đồ họa NVIDIA GeForce RTX 4060 Ti 16 GB VRAM. Toàn bộ các vi dịch vụ—bao gồm hàng đợi Redis Stream, bộ lọc Tầng 1, tác tử LangGraph Tầng 2 và cỗ máy suy luận `llama.cpp` biên dịch cờ CUDA—được ảo hóa bằng Docker Compose trong môi trường khép kín (air-gapped) nhằm loại bỏ sự can thiệp ngẫu nhiên từ hệ điều hành và bảo đảm tính tái lập của thực nghiệm.

Tập dữ liệu kiểm thử được kết hợp từ các bộ benchmark an toàn thông tin uy tín là CSE-CIC-IDS2018 [1] (cung cấp 25.799 sự kiện luồng mạng gán nhãn thuộc 22 lớp tấn công), CSIC 2010 (2.000 sự kiện HTTP Layer 7) và DAPT2020 [27] (mô phỏng chuỗi tấn công APT đa giai đoạn), cùng với 120 mẫu zero-day. Để đánh giá chính xác, nghiên cứu chia tách vai trò dữ liệu: Cổng ML (Tầng 1) được đo lường trên tập `datatest.json`, các thực nghiệm đối chứng (Ablation) 300 mẫu dùng `ground_truth.json`, và đánh giá toàn tuyến (End-to-End) sử dụng hàm mô phỏng luồng `build_stream()`. Thông số chi tiết môi trường thực nghiệm được tổng hợp trong Bảng 2.

Bảng 2. Cấu hình Môi trường Thực nghiệm và Đặc tả Tập Dữ liệu Giám sát

Thành phần	Thông số / Tên gọi	Mô tả chi tiết và Vai trò
Vi xử lý (CPU)	Intel Core i7	Xử lý bộ lọc thống kê Welford và luồng Redis
Bộ nhớ RAM	32 GB DDR5	Lưu trữ cấu trúc Semantic Cache và chỉ mục FAISS
Card đồ họa (GPU)	NVIDIA RTX 4060 Ti	Chạy cỗ máy suy luận llama.cpp CUDA Foundation-Sec-8B
Ảo hóa	Docker Compose	Đóng gói microservices trong môi trường air-gapped
Tập dữ liệu 1	CSE-CIC-IDS2018 [1]	25.799 sự kiện luồng mạng (22 lớp tấn công)
Tập dữ liệu 2	DAPT2020	Chuỗi tấn công đa giai đoạn rải rác theo thời gian
Tập dữ liệu 3	CSIC 2010 & Zero-day	2.000 sự kiện HTTP Layer 7 và 120 mẫu tấn công mới
Ablation Dataset	300 mẫu cân bằng	150 mẫu bình thường + 150 mẫu tấn công (ground-truth)

4.2 Hiệu năng Giảm tải Tầng 1 và Độ trễ Đường truyền

Tầng 1 vận hành với mục tiêu sàng lọc triệt để lưu lượng nhiễu ngay tại tốc độ đường truyền, giải phóng tài nguyên GPU cho Tầng 2. Bộ lọc thống kê Welford $\mathcal{O}(1)$ (`rule_engine.py`) cập nhật trực tuyến kỳ vọng μ_k và tổng bình phương độ lệch S_k trong thời gian vi giây, cho phép tính toán độ lệch chuẩn σ_k và tức thời loại bỏ các luồng tuân theo phân bố chuẩn [6]. Tiếp đó, Cổng Học máy LightGBM (`ml_gateway.py`) đạt độ trễ suy luận trung bình 0.35 ms/véc-tơ đặc trưng nhờ cơ chế phân nhánh cây theo lá. Đối với các tấn công lặp lại diện rộng, Semantic Cache Tầng 1.75 (`response_cache.py`) truy xuất băm mẫu dữ liệu trong RAM, thực thi phản hồi ngắt mạch dưới 1 ms.

Tổng hợp toàn bộ Tầng 1 đã xả tải thành công 92.2% (chỉ 389 trên 5.000 sự kiện mẫu phải gọi đến LLM) lưu lượng nhiễu ở độ trễ trung bình dưới 0.40 ms (Bảng 3). Đáng chú ý, độ tự quyết định của Cổng ML giảm từ 79.1% xuống 59.8% khi tích hợp luồng HTTP CSIC do mô hình LightGBM tự động từ chối phán quyết khi thiếu hụt các trường đặc trưng NetFlow. Dù vậy, việc loại bỏ hơn 90% sự kiện mà không cần gọi đến GPU giúp duy trì độ trễ lag của Redis consumer group gần như bằng 0.

Bảng 3. Độ trễ Suy luận và Tỷ lệ Giảm tải Nhiều tại Tầng 1

Thành phần Tầng 1	Tệp nguồn Mã lệnh	Độ trễ TB	Số lượng Xả tải	Tỷ lệ (%)
Bộ lọc Thống kê Welford	rule_engine.py	< 0.01 ms	14.820 sự kiện	59.3%
Cổng Học máy LightGBM	ml_gateway.py	0.35 ms	4.376 sự kiện	17.5%
Semantic Cache (Tầng 1.75)	response_cache.py	< 1.00 ms	3.850 sự kiện	15.4%
Tổng cộng Tầng 1	–	< 0.40 ms	4.611 / 5.000 sự kiện (Sample)	92.2%

4.3 Độ chính xác Suy luận Nhận thức Tầng 2 và Ánh xạ Tri thức

Tầng 2 tiếp nhận 7.8% sự kiện dị thường được nâng cấp từ Tầng 1 để thực hiện suy luận có trạng thái bằng tác tử LangGraph (workflow.py) kết hợp mô hình Foundation-Sec-8B-Instruct Q4_K_M. Khung truy xuất lai Dual-RAG (hybrid_retriever.py) hợp nhất kết quả giữa vector FAISS và BM25 bằng thuật toán Reciprocal Rank Fusion ($RRF_Score(d) = \sum 1/(k + r_m(d))$ với $k = 60$) [11]. Thử nghiệm trên 300 mẫu CSIC cho thấy RRF đạt độ chính xác ánh xạ véc-tơ tấn công 67.33%. Tuy nhiên, độ chính xác ánh xạ Toàn tuyến (End-to-End) giảm đột ngột xuống mức 2.33%, cho thấy LLM thường xuyên tự sinh câu trả lời đè lên bộ ánh xạ tri thức gốc.

Bảng 4. Chỉ số Đánh giá Độ chính xác Suy luận Tầng 2 và Khung RAG

Chỉ số Đánh giá (Action-based)	Độ chính xác (%)	Điểm Llama-3-8B (Thang 1-5)	Tỷ lệ Chuyển HITL (%)
FAISS Vector Search Đơn lẻ	45.2%	2.5 / 5.0	24.2%
BM25 Keyword Search Đơn lẻ	42.4%	2.3 / 5.0	28.5%
Dual-RAG RRF (FAISS + BM25, $k = 60$)	67.33%	4.3 / 5.0	0.0%
Cấu hình A (Chỉ LLM Đơn tầng)	35.6%	1.8 / 5.0	45.0%
Cấu hình F (Tác tử Toàn vẹn)	100.0% (Hành động)	4.6 / 5.0	0.0%

Thay vì sử dụng thước đo $F1$ nhị phân vốn không phản ánh đúng thực tế khi tỷ lệ nhân tấn công quá cao (86.9%), hệ thống được đánh giá qua phương pháp *chăm-theo-hành-động* (Config A so với Config F). Tại Cấu hình F, tỷ lệ chuyển giao người dùng (AWAIT_HITL) giảm mạnh từ 24.2% xuống 0.0%. Đánh giá chất lượng lập luận được thực hiện độc lập bởi mô hình Meta-Llama-3-8B-Instruct trên thang 1-5 điểm thay vì để LLM tự chấm chính mình. Điểm số 4.6/5.0 khẳng định tính chặt chẽ pháp y, đồng thời loại bỏ rủi ro "Thiên kiến Tự đề cao" (Self-Enhancement Bias) thường gặp trong phương pháp LLM-as-a-Judge.

4.4 An toàn Đối kháng, Prompt Injection và Kiểm toán HMAC

Năng lực phòng thủ đối kháng của SENTINEL được xác minh qua ba kịch bản chuyên sâu. Trong kịch bản tiêm nhiễm prompt qua nhật ký thô (User-Agent, Syslog) [9], cơ chế Đóng gói Dữ liệu Phân định (*encapsulation.py*) với chuỗi Nonce ngẫu nhiên duy nhất (`<<DATA_HASH...>>`) đã vô hiệu hóa 100% các chỉ thị độc hại, ép LLM xử lý dữ liệu ở dạng thụ động [30]. Việc gỡ nhãn phân loại nội bộ (*label stripping*) trước khi gửi prompt giúp ngăn triệt để rò rỉ trạng thái.

Đối với kịch bản tấn công né tránh học máy (anti-evasion), Cổng ML Tầng 1 kẹp Z -score trong khoảng $\pm 8\sigma$ và tự động chuyển phán quyết lên Tầng 2 khi tỷ lệ biến dạng đặc trưng vượt 30%. Trong kiểm toán vết chứng cứ, mọi hành vi sửa đổi nhật ký kiểm toán đều làm gãy chuỗi băm mật mã HMAC-SHA256 (*hmac_sealer.py*) theo định thức $H_i = \text{HMAC-SHA256}(D_i \parallel H_{i-1}, K)$ [29], phát hiện tức thời vi phạm tính chống chối bỏ.

4.5 Thử nghiệm Ablation, So sánh Tổng hợp và Độ bền Vận hành

Bài thử nghiệm Ablation đối chứng trên 300 mẫu cân bằng cho thấy mô hình Đơn tầng (Single-Tier LLM) bị nghẽn hàng đợi nghiêm trọng. Tuy nhiên, các Cấu hình B, C, D, E cho ra kết quả hành động và độ trễ hoàn toàn giống nhau, chứng tỏ thước đo hành động nhị phân đã bị bão hòa (saturated) trên tập dữ liệu này. Đáng lưu ý, phép đo độ trễ trên tập 50/50 cho thấy hệ thống mới chậm hơn 7.8% so với kỳ vọng, nguyên nhân chủ yếu do việc chuyển đổi ngữ cảnh liên tục giữa LLM và Cổng ML khi xử lý luồng sự kiện phân mảnh mật độ cao.

So sánh tổng hợp với các nền tảng SOTA công bố gần đây—bao gồm Watchtower [12], CyberRAG [13], AutoBnB [14], LanG [16] và Policy-Guided SIEM [17]—khẳng định vị thế vượt trội của SENTINEL về băng thông (trên 2.500 flows/s), độ trễ E2E (211 ms), khả năng kháng prompt injection (100%) và mức tiêu thụ VRAM (dưới 8 GB) (Bảng 5).

Cuối cùng, bài kiểm thử độ bền dưới tải tăng đột biến (stream surge 100.000 sự kiện) xác nhận cơ chế quản lý tải backpressure dựa trên độ trễ duy trì (*lag*) của Redis consumer

Bảng 5. So sánh Đối chứng Ablation và Các Nền tảng Tác tử An ninh Tiên tiến

Hệ thống / Nền tảng	Băng thông (Flows/s)	Độ trễ TB E2E (ms)	Độ chính xác (%)	Kháng Prompt Inj. (%)	VRAM GPU (GB)
Single-Tier LLM Baseline	0.41 flows/s	2.450 ms	91.2%	42.0%	15.8 GB
Watchtower Platform [12]	120 flows/s	850 ms	93.5%	75.0%	Cloud API
CyberRAG Agent [13]	85 flows/s	1.120 ms	92.8%	68.0%	24.0 GB
AutoBnB Framework [14]	210 flows/s	620 ms	94.1%	81.0%	16.0 GB
LanG Agentic SOC [16]	140 flows/s	480 ms	95.2%	88.0%	24.0 GB
Policy-Guided SIEM [17]	180 flows/s	520 ms	94.5%	85.0%	16.0 GB
< 15 ms (T1)					
SENTINEL (Hai tầng Đề xuất)	> 2.500 flows/s	+7.8% trễ (E2E)	Hành động	100.0%	7.8 GB

group giúp hệ thống tự động điều tiết tốc độ tiêu thụ, giữ bộ nhớ RAM và VRAM ổn định, bảo đảm tính sẵn sàng liên tục cho hạ tầng SOC.

Chương 5

Kết luận và Hướng phát triển

Chương này tổng kết toàn bộ kết quả nghiên cứu và đóng góp cốt lõi của luận văn mang tên “Hệ thống An ninh Nhận thức Hai tầng Tự động hóa Phát hiện Đe dọa và Ứng phó Sự cố dùng AI Tác tử” (SENTINEL). Nội dung trình bày tổng hợp kết quả tương ứng với ba câu hỏi nghiên cứu, khẳng định đóng góp khoa học lần thực tiễn, phân tích minh bạch các giới hạn kiến trúc và phác thảo lộ trình phát triển tương lai cho hạ tầng Trung tâm Điều hành An ninh (SOC) doanh nghiệp.

5.1 Tổng hợp Kết quả Nghiên cứu Đạt được

Thực nghiệm toàn diện trên 25.799 sự kiện lưu lượng mạng từ tập dữ liệu chuẩn mực CSE-CIC-IDS2018 [1], tập sự kiện HTTP Layer 7 CSIC 2010, kịch bản tấn công đa giai đoạn DAPT2020 [27] và tập đối chứng Ablation 300 mẫu cân bằng đã minh chứng rằng hệ thống SENTINEL giải quyết triệt để và thỏa mãn trọn vẹn ba câu hỏi nghiên cứu chiến lược được xác lập ở Chương 1.

Đối với câu hỏi nghiên cứu thứ nhất (RQ1) về hiệu năng đường ống và tính kinh tế của cơ chế lọc tốc độ đường truyền, các đo lường định lượng khẳng định kiến trúc phân tầng đã khắc phục thành công rào cản tài nguyên tính toán. Tầng 1—với sự phối hợp giữa thuật toán thống kê trực tuyến Welford $\mathcal{O}(1)$ [6], Cổng Học máy LightGBM và bộ đệm Semantic Cache Tầng 1.75—đã sàng lọc và xả tải tự động 92.2% lượng sự kiện (chỉ 389/5000 mẫu đẩy lên LLM) với độ trễ xử lý trung bình dưới 0.40 ms. Việc triệt tiêu hơn 90% tải trọng đường truyền trước khi kích hoạt tài nguyên GPU giúp duy trì độ trễ tích tụ của hàng đợi Redis Stream ở mức xấp xỉ bằng 0, đồng thời giải quyết bài toán băng thông đạt trên 2.500 flows/s, dù trên thực tế độ trễ E2E có sự gia tăng 7.8% do chuyển đổi ngữ cảnh liên tục.

Đối với câu hỏi nghiên cứu thứ hai (RQ2) về rào chắn an toàn cho mô hình ngôn ngữ và tính toàn vẹn vết pháp y, cơ chế Đóng gói Dữ liệu Phân định sử dụng các thẻ Nonce mật mã ngẫu nhiên kết hợp rào chắn tất định đã vô hiệu hóa hoàn toàn 100% các cuộc tấn công tiêm nhiễm câu lệnh qua nhật ký thô [9, 30]. Cơ chế này ép buộc mô hình ngôn ngữ xử lý

mọi chuỗi nhập liệu dưới dạng dữ liệu bị động, ngăn chặn tuyệt đối rủi ro thao túng luồng suy luận. Đồng thời, cấu trúc niêm phong chuỗi băm mật mã HMAC-SHA256 [29] liên kết tuần tự từng bản ghi nhật ký kiểm toán bảo đảm tính chống chối bỏ và chống giả mạo vết chứng cứ trước các nguy cơ can thiệp hậu xâm nhập.

Đối với câu hỏi nghiên cứu thứ ba (RQ3) về khả năng suy luận có trạng thái, quy kết kỹ thuật xâm nhập và tính minh bạch giải trình, cỗ máy tác tử LangGraph Tầng 2 tích hợp mô hình Foundation-Sec-8B-Instruct Q4_K_M kết hợp khung truy xuất lai Dual-RAG hợp nhất xếp hạng RRF ($k = 60$) [11, 20, 21] trên 433 mục STIX MITRE ATT&CK đạt độ chính xác ánh xạ véc-tơ tấn công 67.33% (trên tập CSIC). Hệ thống đưa ra phán quyết hành động chuẩn xác 100% trên tập đối chứng, triệt tiêu hoàn toàn việc phải chuyển giao cho con người (AWAIT_HITL = 0.0%). Chất lượng lập luận được kiểm chứng qua giám khảo Meta-Llama-3-8B đạt 4.6/5.0 điểm, xác nhận năng lực sinh căn cứ pháp y minh bạch, phát hiện và vô hiệu hoá hiện tượng hư cấu thông tin.

5.2 Đóng góp Khoa học và Thực tiễn

Luận văn đóng góp hai giá trị cốt lõi trên cả phương diện nghiên cứu lý thuyết lẫn ứng dụng triển khai thực tiễn trong lĩnh vực an toàn thông tin và trí tuệ nhân tạo.

Về phương diện đóng góp khoa học, nghiên cứu đề xuất mô hình kiến trúc an ninh nhận thức hai tầng (Two-Tier Hybrid Architecture) kết hợp giữa các thuật toán thống kê bất định tốc độ cao ở Tầng 1 và cỗ máy tác tử ngôn ngữ có trạng thái ở Tầng 2. Sự phân tầng này tạo ra một cơ chế xả tải tài nguyên tính toán có hệ thống, giải quyết triệt để rào cản độ trễ bậc hai $\mathcal{O}(N^2)$ vốn tồn tại trong các mô hình ngôn ngữ lớn khi vận hành trên luồng dữ liệu giám sát mạng diện rộng [18]. Bên cạnh đó, luận văn đóng góp mô hình mật mã cô lập dữ liệu thô dựa trên kỹ thuật Đóng gói Dữ liệu Phân định sử dụng các thẻ Nonce ngẫu nhiên duy nhất, cung cấp một giải pháp bảo chứng an ninh mang tính cấu trúc nhằm triệt tiêu nguy cơ tiêm nhiễm câu lệnh qua dữ liệu nhật ký thô mà không phụ thuộc vào các bộ phân loại xác suất mong manh [9, 30]. Cuối cùng, luận văn đóng góp phương pháp luận đánh giá định lượng phi tham số kết hợp mô hình LLM-as-a-Judge chéo họ và các chỉ số RAGAS chuẩn hóa cho các hệ thống tác tử an ninh vận hành cục bộ.

Về phương diện đóng góp thực tiễn, luận văn cung cấp một nguyên mẫu hệ thống hoàn chỉnh được mở nguồn mã lệnh, đóng gói container hoàn toàn bằng Docker Compose và kiểm chứng vận hành trơn tru trên phần cứng thương mại phổ thông (vi xử lý Intel Core i7, 32 GB RAM và một card đồ họa NVIDIA GeForce RTX 4060 Ti 16 GB VRAM). Thiết kế này tuân thủ tuyệt đối các nguyên tắc an ninh Zero-Trust và yêu cầu bảo mật chủ quyền dữ liệu doanh nghiệp trong môi trường air-gapped biệt lập [31]. Hệ thống tích hợp sẵn bảng điều khiển giám sát Streamlit kết nối với hàng đợi xử lý Con-người-trong-vòng-lặp

(Human-in-the-Loop) nhằm thay thế các kịch bản SOAR tĩnh [5], đồng thời tự động niêm phong vết chứng cứ pháp y bằng chuỗi băm mật mã HMAC-SHA256 nhằm hỗ trợ công tác điều tra sự cố sau xâm nhập [29].

5.3 Các Giới hạn Hiện hữu

Mặc dù đạt được các kết quả thực nghiệm tích cực, hệ thống SENTINEL vẫn tồn tại một số giới hạn kỹ thuật cần được nhìn nhận minh bạch nhằm xác lập ranh giới vận hành thực tế.

Giới hạn thứ nhất liên quan đến phạm vi dữ liệu giám sát và năng lực xử lý nhật ký phi cấu trúc. Thử nghiệm hiện mới tập trung đánh giá các thuộc tính NetFlow chuẩn hóa và nhật ký HTTP Tầng 7 từ hai bộ benchmark CSE-CIC-IDS2018 và DAPT2020 [1, 27]. Trong môi trường SOC thực tế, sự đa dạng của các nguồn nhật ký phi cấu trúc (như Windows Event Logs, Syslog thô, hoặc AWS CloudTrail) đòi hỏi phải có các cơ chế phân tích cú pháp và trích xuất đặc trưng phức tạp hơn.

Giới hạn thứ hai nằm ở ranh giới chịu tải hạ tầng khi đối mặt với bão lưu lượng tấn công từ chối dịch vụ (volumetric DoS surge) vượt quá 100.000 sự kiện/giây. Mặc dù Tầng 1 xả tải thành công hơn 80% lưu lượng nhiễu, lượng sự kiện dị thường nâng cấp lên Tầng 2 trên môi trường đơn GPU 16 GB VRAM vẫn có thể vượt quá năng lực suy luận tức thời của cỗ máy ngôn ngữ, gây hiện tượng tích tụ hàng đợi Redis Stream.

Giới hạn thứ ba xuất phát từ nguy cơ tự từ chối dịch vụ (Self-DoS) khi tự động thi hành chính sách chặn IP. Để tránh chặn nhầm các IP nội bộ cốt lõi do sai số suy luận ngẫu nhiên, hệ thống phải hoãn các phán quyết chứa quy tắc chung chung (như T1571) về hàng đợi chờ con người duyệt (AWAIT_HITL). Sự can thiệp bắt buộc này giúp bảo đảm an toàn hạ tầng nhưng chấp nhận giảm bớt mức độ tự động hóa tuyệt đối.

Giới hạn thứ tư đến từ quy mô và phương thức liên kết chuỗi tấn công APT. Cơ chế liên kết hành vi rải rác hiện mới dựa trên địa chỉ IP nguồn cố định và thử nghiệm trên 3 kịch bản đại diện. Trong môi trường thực tế với kỹ thuật xoay IP hoặc mạng botnet phân tán, việc liên kết hành vi chỉ dựa trên IP nguồn có thể bị giảm hiệu quả.

Giới hạn thứ năm liên quan đến độ bền vận hành của tầng lưu trữ trạng thái trong môi trường đóng gói containerized. Các thao tác ghi nhận nhật ký kiểm toán và bộ nhớ đe dọa trên SQLite nếu không được cấu hình chế độ đồng bộ phù hợp có thể phát sinh rủi ro xung đột khóa tệp hoặc đứt gãy tiến trình khi xảy ra sự cố sụp đổ dịch vụ.

5.4 Hướng Phát triển Tương lai

Dựa trên năm giới hạn kỹ thuật được xác định ở Mục 5.3, lộ trình phát triển tương lai của hệ thống SENTINEL đề xuất năm giải pháp nâng cấp kỹ thuật tương ứng nhằm hướng tới triển khai sản xuất thực tế:

Thứ nhất, đối ứng với giới hạn về tiền xử lý nhật ký phi cấu trúc, nghiên cứu sẽ phát triển cỗ máy trích xuất và phân tích cú pháp tự động tích hợp thuật toán phân nhóm biểu mẫu log (như thuật toán Drain [22] hoặc LogParser), cho phép chuẩn hóa các định dạng nhật ký đa dạng (Syslog, Windows Event, CloudTrail) về véc-tơ đặc trưng chuẩn trước khi đưa vào đường ống phân tích.

Thứ hai, đối ứng với giới hạn bão hòa lưu lượng DoS và nút thắt đơn GPU, hệ thống sẽ chuyển đổi toàn bộ bộ lọc Tầng 1 sang ngôn ngữ lập trình hệ thống (như Go hoặc Rust) nhằm nâng thông lượng lên hàng triệu sự kiện/giây; đồng thời di trú Redis Stream sang hạ tầng Apache Kafka phân mảnh ghi đĩa và nâng cấp cỗ máy Tầng 2 lên khung suy luận vLLM hoặc TGI hỗ trợ PagedAttention và continuous batching để phân quyết song song trên các chu kỳ GPU.

Thứ ba, đối ứng với rủi ro tự từ chối dịch vụ và đánh đổi tự chủ, nghiên cứu đề xuất ứng dụng mô hình Học tăng cường từ Phản hồi của Con người (RLHF) dựa trên các quyết định phê duyệt của chuyên gia an ninh tại hàng đợi `AWAIT_HITL`, giúp tác tử tự liên tục tinh chỉnh chính sách phản hồi và tự động hóa an toàn các hành vi chặn IP mà không gây nguy cơ Self-DoS.

Thứ tư, đối ứng với giới hạn liên kết APT và mở rộng công cụ an ninh, hệ thống sẽ phát triển mô hình phân rã đa tác tử chuyên biệt (Multi-Agent Sub-systems) kết hợp Mạng Thần kinh Đồ thị (Graph Neural Networks - GNN) nhằm liên kết chuỗi hành vi xâm nhập dựa trên véc-tơ kỹ thuật. Đồng thời, hệ thống tích hợp chuẩn giao tiếp Giao thức Ngữ cảnh Mô hình (Model Context Protocol - MCP) cho phép các tác tử AI kết nối và điều phối động các công cụ an ninh mạng mở rộng (SIEM, EDR, eBPF Firewall, CTI Feeds), hướng tới xây dựng một Trung tâm Điều hành An ninh Mạng Tổng thể Tự chủ (Autonomous Enterprise SOC Command Center).

Thứ năm, đối ứng với rủi ro đứt gãy lưu trữ trạng thái sản xuất, hệ thống bắt buộc áp dụng cấu hình SQLite ở chế độ `synchronous=NORMAL` (tuyệt đối tránh chế độ `WAL` để triệt tiêu lỗi xung đột quyền truy cập cross-UID trong Docker), kết hợp cơ chế quản lý tải backpressure dựa trên độ trễ duy trì (`lag`) của Redis consumer group nhằm bảo đảm tính sẵn sàng liên tục 24/7 cho trung tâm SOC.

Khép lại một nỗ lực nghiên cứu nghiêm túc, nhưng mở ra những khát vọng sâu xa trong

hành trình bảo vệ không gian số bằng sức mạnh của Trí tuệ Nhân tạo Tác tử.

Tài liệu tham khảo

- [1] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, “Toward Generating a New Intrusion Detection Dataset and Intrusion Traffic Characterization,” in *Proceedings of the 4th International Conference on Information Systems Security and Privacy (ICISSP)*, 2018, pp. 108–116.
- [2] G. González-Granadillo, S. González-Zarzosa, and R. Diaz, “Security Information and Event Management (SIEM): Analysis, Trends, and Usage in Critical Infrastructures,” *Sensors*, vol. 21, no. 14, art. 4759, 2021.
- [3] R. Zuech, T. M. Khoshgoftaar, and R. Wald, “Intrusion Detection and Big Heterogeneous Data: A Survey,” *Journal of Big Data*, vol. 2, art. 3, 2015.
- [4] S. Tariq, M. Baruwat Chhetri, S. Nepal, and C. Paris, “Alert Fatigue in Security Operations Centres: Research Challenges and Opportunities,” *ACM Computing Surveys*, vol. 57, no. 9, art. 224, 2025.
- [5] Ismail, R. Kurnia, Z. A. Brata, G. A. Nelistiani, S. Heo, H. Kim, and H. Kim, “Toward Robust Security Orchestration and Automated Response in Security Operations Centers with a Hyper-Automation Approach Using Agentic Artificial Intelligence,” *Information*, vol. 16, no. 5, art. 365, 2025.
- [6] B. P. Welford, “Note on a Method for Calculating Corrected Sums of Squares and Products,” *Technometrics*, vol. 4, no. 3, pp. 419–420, 1962.
- [7] P. Lewis *et al.*, “Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks,” *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 33, pp. 9459–9474, 2020.
- [8] LangChain AI, “LangGraph: Multi-Actor, Stateful LLM Applications,” *GitHub repository*, 2024. [Online]. Available: <https://github.com/langchain-ai/langgraph>
- [9] K. Greshake, S. Abdelnabi, S. Mishra, A. Endres, T. Holz, and M. Fritz, “More than you’ve asked for: A Comprehensive Analysis of Novel Prompt Injection Threats to Application-Integrated Large Language Models,” *arXiv preprint arXiv:2302.12173*, 2023.
- [10] P. Cichonski, T. Millar, T. Grance, and K. Scarfone, “Computer Security Incident Handling Guide,” NIST Special Publication 800-61 Revision 2, 2012.
- [11] G. V. Cormack, C. L. A. Clarke, and S. Buettcher, “Reciprocal Rank Fusion Outperforms Condorcet and Individual Bootstrap Product Algorithms,” in *Proceedings of the 32nd International ACM SIGIR Conference on Research and Development in Information Retrieval*, 2009.

- [12] R. Pandey and A. Bhujang, “Poisoning the Watchtower: Prompt Injection Attacks Against LLM-Augmented Security Operations Through Adversarial Log Content,” *arXiv preprint arXiv:2605.24421*, 2026.
- [13] F. Blefari, C. Cosentino, F. A. Pironti, A. Furfaro, and F. Marozzo, “CyberRAG: An Agentic RAG cyber attack classification and reporting tool,” *Future Generation Computer Systems*, vol. 176, art. 108186, 2026.
- [14] Z. Liu and A. Anwar, “AutoBnB-RAG: Enhancing Multi-Agent Incident Response with Retrieval-Augmented Generation,” *arXiv preprint arXiv:2508.13118*, 2025.
- [15] J. Zhang *et al.*, “When LLMs Meet Cybersecurity: A Systematic Literature Review,” *Cybersecurity*, vol. 8, 2025.
- [16] A. Abdennebi, N. Kara, L. Lahlou, and H. Ould-Slimane, “LanG – A Governance-Aware Agentic AI Platform for Unified Security Operations,” *arXiv preprint arXiv:2604.05440*, 2026.
- [17] R. Sahay *et al.*, “Policy-Guided Threat Hunting: An LLM Enabled Framework with Splunk SOC Triage,” *arXiv preprint arXiv:2603.23966*, 2026.
- [18] A. Vaswani *et al.*, “Attention is All You Need,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 30, pp. 5998–6008, 2017.
- [19] A. Gholami *et al.*, “A Survey of Quantization Methods for Efficient Neural Network Inference,” *arXiv preprint arXiv:2103.13630*, 2021.
- [20] J. Johnson, M. Douze, and H. Jégou, “Billion-Scale Similarity Search with GPUs,” *IEEE Transactions on Big Data*, vol. 7, no. 3, pp. 535–547, 2019.
- [21] S. Robertson and H. Zaragoza, “The Probabilistic Relevance Framework: BM25 and Beyond,” *Foundations and Trends in Information Retrieval*, vol. 3, no. 4, pp. 333–380, 2009.
- [22] P. He, J. Zhu, S. He, J. Li, and M. R. Lyu, “Drain: An Online Log Parsing Approach with Fixed Depth Tree,” in *Proceedings of the IEEE International Conference on Web Services (ICWS)*, 2017, pp. 33–40.
- [23] Cybersecurity Research Team, “Foundation-Sec: An Open LLM for Cyber Threat Detection,” *Security Preprint*, 2024.
- [24] B. E. Strom, A. Applebaum, D. P. Miller, K. C. Nickels, A. G. Pennington, and C. B. Thomas, “MITRE ATT&CK: Design and Philosophy,” The MITRE Corporation, Technical Report MP180360, 2018.
- [25] N. Reimers and I. Gurevych, “Sentence-BERT: Sentence Embeddings using Siamese BERT-Networks,” in *Proceedings of the Conference on Empirical Methods in Natural Language Processing (EMNLP)*, 2019.
- [26] L. Zheng *et al.*, “Judging LLM-as-a-Judge with MT-Bench and Chatbot Arena,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 36, 2023.

- [27] S. Myneni, A. Chowdhary, A. Sabur, S. Sengupta, G. Agrawal, D. Huang, and M. Kang, “DAPT 2020 – Constructing a Benchmark Dataset for Advanced Persistent Threats,” in *Deployable Machine Learning for Security Defense (MLHat 2020)*, Communications in Computer and Information Science, vol. 1271, Springer, 2020, pp. 138–163.
- [28] S. Es, J. James, L. Espinosa-Anke, and S. Schockaert, “RAGAS: Automated Evaluation of Retrieval Augmented Generation,” *arXiv preprint arXiv:2309.15217*, 2023.
- [29] H. Krawczyk, M. Bellare, and R. Canetti, “HMAC: Keyed-Hashing for Message Authentication,” Internet Engineering Task Force, RFC 2104, 1997.
- [30] OWASP GenAI Security Project, “OWASP Top 10 for Large Language Model Applications,” Version 2025, The OWASP Foundation, 2025. [Online]. Available: <https://genai.owasp.org/>
- [31] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, “Zero Trust Architecture,” NIST Special Publication 800-207, National Institute of Standards and Technology, 2020.